

Smart World

IT General Control Policy

Document Control	
Document Title: IT Policy and General Controls	Version: 01
Document Owner:	Review Frequency: Annual 30 th April 2025
Department: Information Technology	Effective Date:

Authorization		
Prepared By	Reviewed By	Approved By
Signature / Date	Signature / Date	Signature / Date

Revision History				
Version No.	Effective Date	Prepared By	Approved By	Description
Version:02	01-May-2024	Ranjit Sarkar	Nitin Gupta (HOD-IT)	Updated Incident, Backup & Restoration Management Policy.
Version 3	10.07.2025	Ranjit Sarkar	Nitin Gupta (HOD-IT)	Updated Incident SLA & incident workflow
Version 4	17.03.2026	Ranjit Sarkar	Nitin Gupta (HOD-IT)	Updated UAR reviewer, FFID user, SAP User role, SAP logs review period, Lost asset, Backup retention

Sr. No.	Subject	Page no.
1	Introduction	4
2	Structure of Policy	5, 6
3	References	6
4	High Level Information Security Policy Statements	7,8 ,9,10,11,12
5	Lost & theft of asset	13,14
6	Information Classification, Labelling and Handling	15,16,17,18
7	Access Management (User access Management, UAR reviewer, Access control SAP, Periodic review, Access control)	19,20,21,22,23,24,25,26,27
8	Operation Management (Change Management, Backup & restoration, Logging & Monitoring)	28, 29,30,31,32
9	Technical Vulnerability Management & Communication Security	33,34,35,36
10	Suppliers & partners	36, 37
11	Business Continuity & incident Management	37,38,39,40,41, 42, 43

A. Introduction

1. Objectives

This Policy provides the framework to ensure the protection of information systems and assets of SmartWorld, and to allow the use, access, and disclosure of such information.

The specific objectives of the policy are:

- **Confidentiality:** To prevent unauthorized disclosure of information stored or processed on Smart World information systems.
- **Integrity:** To prevent unauthorized, accidental or deliberate alteration of information.
- **Availability:** To ensure appropriate and adequate information and systems for processing the information are available when an authorized person or organization demands it.

The policy statements mentioned in this document are derived based on the business requirements and risks prevailing due to external and internal issues.

2. Scope

This policy applies to all users of SmartWorld (Includes Smartworld Developers Pvt. Ltd., its subsidiaries, joint ventures & associates) and other non-SmartWorld users such as third-party service providers. Such users include but are not limited to permanent employees, temporary employees, trainees, vendors, contractors, business partners and other related third-party personnel as well as project companies, asset companies, SPVs and their permanent employees, temporary employees, trainees, vendors, contractors, business partners and other related third-party personnel (In a case where a partner provides security policies and guidelines, it will be applicable in addition to this Policy.) Where the two policies (the partner's policy and SmartWorld Policy) are in conflict, the more restrictive of the two will be applicable.

3. Applicability

Throughout this policy, the terms "organization", "business" and "Business/ Unit" identify SmartWorld. In compliance with industry rules, the organization provides for the security and privacy of the data stored on, redirected through, or processed by its technology resources. The organization encourages the use of these technology resources; however, they remain the property of the organization and are offered on a privilege-basis only. Throughout this policy, the terms "employee", "users" and/ or "staff" identifies full- and part-time employees, contractors, consultants, temporaries, student assistants, volunteers, separated employees, retired employees, vendors and other users including those affiliated with third parties who access the organization's technology resources in the course of their job responsibilities. The management expects employees to comply with the mandates in this document, and other applicable organization policies, and procedures. The management expects employees to also comply with local, state, country, and international laws in the course of their duties. Failure to abide by these conditions may result in forfeiture of the privilege to use technology resources, disciplinary action, and/or legal action, on the discretion of the management of SmartWorld. Management understands the need to regularly modify this and other information security related policies to reflect the changes in industry standards, legislation, technology and/or products, services, and processes at the organization. Human factors associated with policy development, implementation, and practice play a significant role to best ensure the success of policy.

B. Structure of Policy

1. Policy Statement

This policy statement is an overall declaration of SmartWorld security expectations, which will allow effective utilization of information systems to foster SmartWorld business goals.

2. Purpose & Objectives

The purpose and objectives of the policy is to provide a brief on the areas covered by the policy and appropriately define and set procedures for SmartWorld information processing systems.

3. Level of Security

The level of security required for information systems and assets is dependent upon the value of the information or the impact of the loss of assets to SmartWorld, the risks to which they are exposed and the extent to which they are affected by legal and regulatory requirements.

The policies provided in this document shall be implemented for all information systems of SmartWorld. SmartWorld will review where existing systems do not comply with the policies; the risks associated with non-compliance and the expected life of the system, and determine the appropriate action, if any.

This policy document defines the policy and responsibilities for information security. Its implementation must be reviewed independently to provide assurance that the practices properly reflect the policy and that it is effective. A full-fledged review must be conducted at least once in a year by an independent entity, Risk Management & IT team jointly.

4. Monitoring Implemented Controls

To ensure effectiveness of the security controls that have been implemented, the IT head will measure the controls that have been implemented for their effectiveness.

5. Maintenance

This Policy shall be reviewed by Management at least once a year or as deemed necessary based on changes in technology, business, legal, regulatory, risk and/or customer requirements. This policy document must be approved after appropriate internal review and consultation with compliance, legal and business heads and internal subject matter experts. Individual business stake holders, and project / department heads, may provide additional guidance that could be included as an annexure to this document when it is business specific, and/ or updated in the primary document as necessary.

6. Enforcement

Violations of this Policy may result in disciplinary actions depending on the nature of the violation. Disciplinary actions may apply up to and include termination of employment or contract. Civil, criminal and/or other applicable legal actions may also follow depending on

the nature and location of violation.

7. Compliance Measurement

Compliance with this policy is mandatory. Compliance with this policy will be subject to periodic review by the IT Department and the Risk Management team, in consultation with the IT Management and Company / Group Management (if any, from time to time)

8. Exceptions

Exceptions to this policy for any property must be documented and approved after consulting and receiving the necessary approvals from the CRO & IT Head. Risks occurring due to such exceptions and the available compensating controls shall be clearly documented by the property. Policy exceptions will be reviewed on a periodic basis for appropriateness.

C. References

ISO 27002: 2013 Information Technology – Security techniques – code of practice for information security controls.

ISO/IEC 270001:2013 Information technology – Security techniques – Information security management systems – Requirements, Second edition 2013-10-01

NIST SP-800-82 Guide to Industrial Control Systems (ICS) Security

D. High Level Information Security Policy Statements

1. Management Direction for Information Security

Policy Statement

Management commitment to the IT will be achieved by leading through example and developing organizational role within the IT. This policy has been developed and maintained taking into consideration the security objectives of SmartWorld and all applicable security requirements.

Purpose and objectives

Objective of this policy is to guide the senior management of SmartWorld, as well as individual departments in their roles and responsibilities for managing Information Security in accordance with business requirements and relevant laws and regulations. Organizational roles have been established to contribute to the on-going effectiveness of the IT.

S. No	Description	Responsibility
A.	An information security framework must be adopted by SmartWorld. The set of policies defined within this framework must be approved by management and published for general consumption by all entities affected by	Management
B.	SmartWorld must define Minimum Baseline Security Standards (MBSS) and Controls.	Management, IT
C.	The information security policies and procedures must be communicated to the intended audience through use of relevant, accessible and understandable information security awareness and training program.	Management, HR
D.	When distributing information security policies outside SmartWorld., care must be taken to not reveal confidential	Management

2. Risk Assessment and Treatment

Objectives

Objective of policy also includes the need to ensure that information security risks are identified, mitigated and monitored on a continuous basis, across the group.

Policy Statements

S. No	Description	Responsibility
A.	Define and apply an information security risk assessment process that establishes and maintain an information security risk criterion	Management
B.	Information Security Risk criteria would include: 1. Risk acceptance criteria	Management

S. No	Description	Responsibility
	2. Criteria for performing information security risk assessments	
C.	The risks must be assessed under three categories viz. confidentiality, integrity, and availability of information	Management
D.	Retain documented information about the information security risk assessment process	Management

3. Measurement of Effectiveness and Monitoring

Objectives

Objective of this policy is to assist SmartWorld in gaining an insight into the adequacy and effectiveness of information security controls, to plan for year-on-year improvement of information security practices.

Policy Statements

S. No	Description	Responsibility
A.	SmartWorld must establish metrics that measure the effectiveness of its security policy enforcement, supporting procedures and technical controls.	IT Operations* Manager
B.	A non-conformance may occur due to lack of implementation of a control or a group of controls or a faulty implementation. A formal procedure must be established for its identification, classification, resolution and mitigation.	IT Operations Manager
C.	IT Team must collect and maintain all information security incident reports, audit findings, monitoring reports, security tests, effectiveness measurements and suggestions.	IT Operations Manager

* IT operation manager is main SPOC for respective sub-functions such as SAP & SFDC (Neeraj Kalra), IT Infra & Security (Ranjit Sarkar)

4. Corrective Action and Continuous Improvement

Objectives

Objective of this policy is to outline the process for identifying, analyzing and monitoring corrective actions.

Definitions

“Corrective actions” are improvements to an organization’s processes to eliminate causes of non- conformities or other undesirable situations such as information security incidents and breaches.

Policy Statements

S. No	Description	Responsibility
A.	Internal/external audits Management reviews of Information Security Management System (IT) effectiveness	IT Operations Manager
B.	Information security breaches and incidents Violation of security policy and security objectives implementation vis-à-vis the documented IT Policy.	System Administrator
C.	All identified non-conformities must be recorded with classification highlighting their business impact (e.g. critical, high, medium, low, no impact etc.). Utilize the standardized risk assessment framework to apply the classification score.	IT Team
Analysis		
A.	Managers / Functional Heads in consultation with the relevant teams must conduct the following activities for the identified observation / non-conformance: 1. Identify action steps to contain the observation/non-conformance. 2. Conduct root cause analysis 3. Develop a plan to mitigate or treat/transfer/reduce the risk	Functional Heads
B.	Plan of action must be documented with target end date and responsible owners. In an event that an extension is necessary, a reasonable justification must be logged.	Functional Heads
Implementation and Records		
A.	Relevant teams ('implementers') must document a correction action plan and implement the actions.	IT Team
B.	The implementers must retain documented information (corrective action log) as evidence of: • The nature of the nonconformities and any subsequent actions taken. • The results of corrective actions including technical description of corrective actions taken. • Status of the corrective actions	IT Team
C.	Verify the accuracy and completeness of the corrective action log periodically.	IT Operations Manager
Monitoring		
D.	IT Operations Manager must review the corrective action status periodically. The non-conformities must be closed within an acceptable time frame.	IT Operations Manager
E.	IT Operations Manager must prepare a report on the corrective action logs as per defined timeline.	IT Operations Manager
Evaluate		
F.	IT Operations Manager must evaluate the need for action to eliminate the causes of nonconformity, in order that it does not recur or occur elsewhere by: • Reviewing the non-conformity, • Determining the causes of the non-conformity • Determining if similar non-conformities exist, or could potentially occur • Implement an action needed	IT Operations Manager
Review		

S. No	Description	Responsibility
G.	The effectiveness of the corrective actions must be reviewed by the IT Operations Manager during scheduled internal audits and subsequent changes to the IT must be made, if necessary.	IT Operations Manager
H.	Retain documented information as evidence of the nature of non-conformities and any subsequent action taken and the results of any action taken.	IT Team
Continual Improvement		
I.	The organization shall continually improve and update all the underlying processes and policies in order to maintain suitability, adequacy and effectiveness of the Information Security Management System.	Management

5. Project Management

Objectives

The Objective of this policy is to provide and support effective management of all information security programs and projects in alignment with the enterprise strategy.

Policy Statements

S. No	Description	Responsibility
A.	Projects, related to information security within SmartWorld, must be developed, maintained, and must include the required costing and resource requirements.	IT Project Manager
B.	Program performance must be managed against pre-defined criteria (e.g. Time, Cost Quality, and Quantity).	IT Project Manager
C.	Stage-gate reviews must be undertaken to monitor and report the progress and benefits of the program to relevant stakeholders.	IT Project Manager
D.	Project management framework must be established and managed for each project, which must include: - - Defining the scope and boundaries of managing projects. - Selection of project management approach based on size, complexity, and regulatory requirements. - Designing project governance structure to define roles, responsibilities, and accountabilities of each stakeholder	IT Project Manager

6. Information and Asset classification and control

Asset Management

Policy Statement

All information systems hardware (e.g. laptops, PCs, storage media, printer, photocopiers, etc.) will be physically identified and inventoried, as being owned by SmartWorld and the designated owner will be responsible for management of the equipment.

Purpose & Objectives

Purpose of this policy is to identify organizational assets and define appropriate protection responsibilities across the complete asset lifecycle.

S. No	Description	Responsibility
Inventory of Assets		
A.	IT department will maintain an updated information asset inventory which must contain the following information as a minimum: 1. Identification 2. Description 3. Location 4. Owner 5. Asset classification	System Administrator / IT Team
B.	The assets such as Laptops, Desktops, and Printers etc. must be inventoried with a unique asset identification code. The asset identification code must follow a naming convention that identifies the assets in a unique and appropriate manner.	System Administrator / IT Team
C.	A review report of the IT asset inventory must be submitted to the IT Operations Manager on a bi-annual basis.	System Administrator / IT Team
D.	Criteria for IT asset expiry shall be identified and documented. Extension of IT assets shall be approved by authorized stakeholders.	System Administrator / IT Team

E.	All IT assets that are lost or stolen must be reported within SmartWorld as per Information Security Incident Management Policy and Procedure.	System Administrator / IT Team
Asset Ownership		
A.	IT assets shall be assigned/ tagged to individual users in the IT asset inventory.	System Administrator / IT Team
B.	IT department shall ensure asset recovery in case of user separation/transfers (as appropriate) in collaboration with HR and other departments.	System Administrator / IT Team
C.	IT assets temporarily allocated to users for use are subject to: ▪ Approval from the Department / Project Manager ▪ IT department having secured the asset as per the Information Security Policy of SmartWorld	System Administrator / IT Team
Return Assets		
A.	IT assets must not be exchanged, traded or "cascaded" by the asset owner. The company remains the primary owner of all IT assets and any re-assignment must be approved by authorized personnel and documentation for the same must be maintained.	All Employees/System Administrator
B.	All assets must be returned to IT team: • On the last working day, by employees who are separating from SmartWorld. • By employees who receive new assets as replacement against previously owned assets. • Unwanted/unneeded IT assets.	All Employees/System Administrator

Lost & theft Asset / Accessories:

Notified to IT, Admin & HR:

- **Lost report should be logged by respective coping HR & HOD to IT department through mail.**
 - Lost within Office – CCTV Search report / log report / Mail conversation to admin on lost report should be attached with Notification Email. Admin must submit the conclusion report on the incident. HR & IT Head will jointly decide for waiver or recovery as a case may be basis the report.
 - Lost out of Office – Copy of FIR should be attached with Notification email. Admin to extend all the support with regards to police & other agencies. HR & IT head will jointly decide for recovery only when gross negligence is proved.
- **Deduction eligibility:**
 - 100% asset amount will be applicable for payment in case of no notification or missing attachment. For assets beyond two-year WDV as per books will be considered for recovery
 - Any Waiver request shall be approved by approvers (user's HOD, HR & IT Head).
 - Based on approval, amount will be deducted from salary or paid by user to acquire new asset or Accessories.

Replacement of Asset (Laptop/Desktop/IPAD) / Accessories (Mouse / Charger / Bag / Digital Pen) * :

Sno	Asset / Accessories	Applicable Criteria	Approval Required	Applicable Cost**
1	New Laptop	3 years after issuance date	IT HOD	No
2	Upgradation or change of laptop	1 year after issuance date	User's HOD IT HOD	No
3	Change of Laptop	Before 1 year	User's HOD IT HOD MO Approval	No
4	Change of Laptop due to Hardware Issue (Only in case of negligence)	Within 3 years of Issuance date	IT HOD	As per applicable repair charges (if any)
5	Accessories replacement due to non-functioning or damaged (Only in cases of gross negligence)	Before 1 year	IT HOD	0-6 months – 100 % Accessories value 7-12 months - 50% of Accessories value
6	Accessories replacement due to non-functioning or damaged	After 1 year	IT HOD	No

*All replacements are subject to availability of Asset / Accessories.

**Applicable cost will be deducted from salary or paid by user to acquire new asset or Accessories.

Deduction at F & F Clearance:

Sno	Asset / Accessories	Applicable Criteria	Applicable deduction	Waiver Applicable
1	Laptop	System is in Working status	No	No
2	Laptop	System is in non-working status (Only in case of any negligence)	Yes (As per applicable repair charges)	No
3	Accessories (Mouse / Charger / Bag / Digital Pen)	Not submitted (all or anyone from assigned accessories)	Yes (As per applicable charges)	IT HOD HR Head

Information Classification, Labeling and Handling

Policy Statement

SmartWorld Assets / Information will be classified to indicate the need, priorities and degree of protection and to communicate the need for appropriate handling measures to users.

Purpose & Objectives

Objective of this policy is to outline controls related to classification, labelling and handling of information assets based on its level of sensitivity.

S. No	Description	Responsibility
Information Classification		
A.	All the information and data within SmartWorld must be classified under one of the following four categories: Restricted Information: Information must be classified as restricted when unauthorized disclosure, alteration or destruction of that information provides access to business secrets could jeopardize important interests or actions of SmartWorld or its clients and would lead to the serious personal or financial detriment. Confidential Information Information must be classified as confidential when unauthorized disclosure, alteration or destruction of that information may lead to financial loss, legal proceedings, reputation damage and regulatory compliance issues to SmartWorld. Internal Information Information must be classified as internal when unauthorized disclosure, alteration or destruction of that information may cause risk including but not limited to loss of operational effectiveness, leverage to competitor, and reduction of customer confidence in SmartWorld's business practices. By default, all information assets which are not explicitly classified as confidential or public information or are unclassified must be treated as internal information. Public Information Information must be classified as public when the unauthorized disclosure of that information would result in minimal or no risk to SmartWorld. While no controls are required to protect the confidentiality of public information, some level of control is required to prevent unauthorized modification or destruction of public information.	Management
Information Labelling		
A.	To ensure that the appropriate controls are applied to the information assets of SmartWorld, procedures must be defined to label information assets based on sensitivity of the information during information creation, processing, transmission and storage.	IT Administrator and All employees using assets /

S. No	Description	Responsibility
B.	Information labelling and handling procedures must be developed, commensurate with the level of classification.	IT Administrator and All employees using assets /
Information Handling		
A.	All information must be handled according to the classification categories to ensure security of the information resource.	All Employees
Information Storage		
A.	Department Head and Project Manager must work with the IT department to determine the technical controls to be implemented in order to secure information stored.	Functional Heads
B.	IT must implement encryption technology to secure IT assets as required.	IT Administrator and All employees using assets / information
C.	IT must maintain a record retention schedule to manage the duration of storage of information.	IT Administrator and All employees using assets / information
Information Disposal		
A.	Formal procedures for the secure disposal of IT assets must be established to minimize the risk of sensitive and confidential information being disclosed to unauthorized persons	IT Administrator and All employees using assets /
B.	Papers with internal and confidential information must be shredded after its business use unless such information is required to be retained as per applicable data retention laws.	All Employees
C.	Internal and confidential information on memory devices must be irretrievably deleted prior to disposal/ return/ replacement after its business use.	All Employees

Record Management (Digital Records Only)

Policy Statement

Critical records of SmartWorld shall be managed efficiently throughout its entire life cycle. This will ensure that:

- Records are easily and efficiently located, accessed and retrieved
- Records are adequately protected and securely stored
- Records being disposed safely and at the appropriate time

Purpose & Objectives

Objective of this policy is to ensure that critical records (which, if disclosed without authorization, would be detrimental to the interests of SmartWorld) within SmartWorld are

created, managed, retained and disposed of appropriately, and in accordance with relevant applicable legislation.

S. No	Description	Responsibility
Record Maintenance		
A.	All the records must have at least following information. 1. Record owner 2. Record classification i.e. critical and non-critical. 3. Record retention period till which records spanned out in this policy must be retained.	All Employees, IT Team
B.	Records must remain legible, readily identifiable, retrievable, accurate, authentic and credible. For an electronic record, an audit trail must identify any changes.	All Employees
C.	Access to records must be given on need-to-know basis and must require approval of department Head.	All Employees
D.	Controls must be defined and implemented for classification, storage, transmission, retrieval and disposition of records. The controls shall also comply with local legal and regulatory requirements, applicable standards and contractual obligations.	IT Operations Manager, All Employees and Legal Team
E.	Records containing Personally Identifiable Information (PII) must be protected.	All Employees / IT Team / Legal Team
Record Retention and Disposal		
A.	Retention periods for records must be decided based on the following: 1. Business requirements 2. Legal or regulatory compliances 3. Contractual obligations 4. Customer requirements	Administrator / Facility Management Services
B.	On completion of the retention period, the record owner can extend the retention period, with appropriate business justification. The extension must be approved by the Functional Head.	All Employees/ Functional Heads
C.	Records must be destroyed/ disposed accordance with 'Information Retention and Disposal Policy' and should be done only after approval of record owner. Logs must be retained for destroyed records for future reference.	All Employees/ IT team
IT Service Requests		
A.	All IT service requests must be logged (either through helpdesk software or a register) and retained for a minimum period	IT team
B.	A backup log or register containing all details of the backups taken must be maintained	IT team
Audit Logs		
A.	The Audit Trails and Logs (e.g. Firewall logs, IDS logs, logs from network devices like router, switch etc., operating systems logs, database systems logs, ERP access logs, proxy server logs, DLP logs, authentication logs, E-mail transport logs, web server logs, anti-virus logs) must be maintained in a secure manner for a defined period (as defined by business/regulatory requirement) in an online search/retrieval system:	IT team

S. No	Description	Responsibility
E-Mails		
A.	All e-mails communication including email transport and access logs must be maintained online. Post which, any record that classifies as business records (sent or received) with a longer retention period, should be stored outside of the email.	System Administrator
B.	Emails quarantined at the email gateway must be retained with email attachments, if any, as per requirement of applicable laws before being deleted.	System Administrator
System Development and Maintenance		
A.	The IT Department will retain all change request forms and change documentation and update of system documentation reflecting the change. Post which, any record that classifies as business records (sent or received) with a longer retention period, should be stored outside of the email. The active and disabled email-ids will be reconciled with HR records monthly.	IT Team
Information Security Policies, Procedures and Guidelines		
A.	All information security policies, procedures, guidelines and related documents must be maintained in a secure manner.	Management
B.	Requests and approvals for exceptions to IS policies must be retained till the exception is in force / audit whichever is later.	Management
C.	Businesses can choose to maintain/store/destroy records as per their applicable laws, risk, regulations and/or contractual obligations by requesting an exception to this policy.	Management / Legal Team
System Documentation		
A.	Valid system documentation (documentation on the management of IT Systems) that supports SmartWorld complete system management must be developed, maintained, updated, and protected. The same must be approved by IT Operations Manager	IT Operations Manager
B.	IT Operations Manager shall review system documentation on an annual basis to ensure its accuracy and currency.	IT Operations Manager

7. Data Protection

Policy Statement

All employees are responsible to provide adequate safeguards to protect data and information within SmartWorld. Head IT will provide guidance to functional heads on individual responsibilities towards data protection and privacy. The functional heads will be responsible to inform the IT team about the storage requirements for information and controls required for protection and privacy of information.

Purpose and Objectives

The objective of this policy is to ensure security and privacy of Personally Identifiable Information (PII), Sensitive Personal Identifiable Information (SPII), and Personal Health Information (PHI) gathered, stored and/or processed by SmartWorld (where applicable).

8. Access Management

Access Control & User Access Management

Policy Statement

All access to company confidential records like customer contracts, personal records and financial information shall be controlled and provided adequate protection to minimize any security breach

Purpose & Objectives

Access to SmartWorld information and IT assets shall be authorized based upon roles, on a need-to-know basis and for performance of tasks. The usage of these resources shall be monitored and controlled through appropriate authentication procedure of respective functions. Proper records shall be maintained for the same

S. No	Description	Responsibility
Business Requirement of access control		
1. Access Control Policy		
A.	All contractual obligations regarding protection of (or access to) data and services shall be considered before granting access.	IT Team
B.	Access to information resources shall always be granted in business need, and least privilege principle and the same shall be documented.	IT Team
2. New ID Creation and modification		
A.	- A formal user registration process should be defined in consultation with business and HR for the creation of user ID, assigning access privilege levels. - Modification of assigned access privilege levels for new employees/third parties or groups. It should include approval of access rights from authorized personnel before granting access.	HR /User HOD/ IT Team

S. No	Description	Responsibility
3. User Account Deactivation		
A.	All users must follow a formal de-registration process for revocation of access to information systems and services which must include timely intimation and revocation of access rights.	All Employees / IT Team
4. User Access Management - General Clauses		
A.	Configure access controls based on roles and/or business need for high assurance systems and logical access. A formal review, correction/mitigation and documentation procedure should be in place to avoid conflicts such as Segregation of Duties (SOD). It should be done in 6 months.	Functional heads
B.	User access monitoring reviews must be conducted to monitor access rights or privileges assigned to the corresponding system periodically. Any exceptions noted must be addressed at the earliest by the relevant authorities.	HR/ IT Team
C.	Access privilege accounts must be restricted to specific systems	IT Team

S. No	Description	Responsibility
	through use of a privileged identity management solution.	
D.	Ensure that all computerized systems must require, at minimum a username and password combination, before granting access to the system. This also involves peripherals, embedded systems, network equipment, printers, shop-floor computer systems, remote-access modems.	All Employees

Below are the details for UAR reviewer.

Sr. No.	Application	Process	Reviewer
1	SAP	Procurement	Udit Kaushik
2	SAP	IT	Nitin Gupta
3	SAP	Admin	Devinder Singh Malik
4	SAP	Marketing	Jyotsna Chauhan
5	SAP	CRM	Paramvir Singh Rai
6	SAP	Sales	Sachin Suri
7	SAP	HR	Vikas Malhotra
8	SAP	Finance	Rajat Jain
9	Salesforce	CRM	Raghav/Paramvir
10	Salesforce	Sales	Ashish Jerath
11	Salesforce	Audit	Abhishek
12	Salesforce	Finance	Rajat Jain
13	Salesforce	IT	Nitin Gupta
14	4 QT	CRM	Raghav/Paramvir
15	Office 365	IT	Nitin Gupta

Final review & conclusion will be done by IT Head. He will have sole authority to review & modify the rights of the user to maintain overall IT governance.

Access Control - SAP

Policy Statement

Access to SmartWorld systems and applications will be restricted by putting in place security controls so that access to confidential records like customer contracts, personal records and financial information shall be controlled and adequate protection can be provided to minimize any security breach

Purpose & Objectives

Objective of this policy is to identify security controls to prevent unauthorized access to applications.

S. No	Description	Responsibility
Production System - New user creation		
A.	Access approvals records should be maintained for all accesses provided to the production environment. A request for a new user creation must be raised in ManageEngine via email on IT ServiceDesk email ID or directly via ManageEngine. After functional manager approval on user creation and appropriate rights, SAP team will create the user in SAP application. SAP team creates the user's SAP ID and assigns few/all the approved roles. Security team communicates the logon credentials to the use in a separate email and will close the ticket At any point, the status of the request and the status of approvals/rejections shall be viewed in the system.	System Administrator / Functional Manager
5.5. Handling user deletion transfer or expiration		

S. No	Description	Responsibility
A.	Security team expires a user's access by end dating the current assignments and locking the account when, ▪ A request is initiated in ServiceNow when user shouldn't require access pertaining to existing position. ▪ A user leaves the company and HR system notifies the security team. Security team will deactivate the user on the same date when HR notifies. On or before last working day. ▪ A user is inactive for more than 30 days The reporting manager informs the Human resources team if the user has left the company or if the user's contract has ended by initiating a request in ServiceNow and HR team processes the request by entering termination date in the HR information system. HR information system sends an automated notification to the SAP Security team. On a periodic basis security team verifies with the old and new reporting manager if the user's SAP access needs to be changed as part of this transition. If the change is required, the new reporting manager initiates a ServiceNow request to the SAP Security team. Security team then verifies the request and will make changes. The new reporting line manager will also initiate a new sap access request pertaining to the new position. In case of absconding employees, as per the policy, HR must inform to IT for deactivation on the date it is ascertained that employee is absconding. If such date is in past, specific reason to be documented and approved by CRO.	System Administrator
Periodic Reviews		

S. No	Description	Responsibility
A.	<u>Periodic Reviews</u> SAP Security team runs periodic reports to remove the dormant users from the system. Users who are locked and inactive for more than 30 days will be deactivated from the system and access will be resume basis HOD approval. User or role will be granted access to powerful profiles SAP_ALL or SAP_NEW in production only for 2 users (KNeeraj (Admin) & Sage Basis (Basis) till 31st March 26 to check & resolve integration issues as Smart world gone live recently On monthly basis Security team will run a report to check that none of these powerful profiles have been granted to any user or role. Security team will make sure that they do not assign access to these profiles to any user belonging to any team including the Security team. Powerful ID like FFID is locked at all times. On a periodic basis Security team will run a report to check that these user IDs have not been unlocked in production and that no activities are executed by these user IDs. Security team will make sure that they do not unlock these user IDs. Log to be signed or approved on email by IT Head and stored in shared drive.	System Administrator
B.	<u>Periodic Reviews</u> On half yearly basis, SAP Security team will extract list of all active users, and their composite roles assigned from system and send it to Role Owners to have it validated. SAP Security team will accordingly process any modification or deletion suggested by the Business and IT Role Owners. Logs will be generated by Functional teams or Security team to provide tighter control if inappropriate activity has been identified by the Business and IT Role Owners during the review process On a half yearly, the SAP Security team will check the terminated users against users who have been mapped to mitigation controls and will delete the users from the Mitigation Control Matrix and confirm new mitigation control owners (if an existing mitigation control owner is removed) On a half yearly, the security team will route the updated role owner matrix for approval SAP Security team extracts reports from the non-production systems, regarding inactive users and deletes the users and shall track this activity in ServiceNow. Any unwanted or unassigned	IT Operations Manager
Third Party Access Rights		

S. No	Description	Responsibility
A.	Third party vendor access is requested by - Filling out the SAP Access request form, this needs to be approved by Vendor Manager. In the absence of vendor manager, form will be approved by IT Head. - The form should specify the validity period for the vendor id - The Security team receives a request and verifies if the form is approved by the right authorities for the specified validity period and confirms approval from role owner based on the role owner matrix - Security team assigns the vendor management roles and contacts the requestor with the login credentials - All the vendors' access roles are pre-approved by vendor Manager. In all cases validity must no exceed 90 days.	Systems Administrator

Access Control- Other Systems and Applications

Policy Statement

Access to SmartWorld systems and applications will be restricted by putting in place security controls so that access to confidential records like customer contracts, personal records and financial information shall be controlled and adequate protection can be provided to minimize any security breach

Purpose & Objectives

Objective of this policy is to identify security controls to prevent unauthorized access to applications.

S. No	Description	Responsibility
Information Access Restriction		
A.	Access to information and application system functions must be restricted.	Systems Administrator
Secure Log-on Procedures		
B.	Access to applications must be controlled by a secure log-on procedure.	Systems Administrator
C.	Where strong authentication and identity verification is required, authentication methods in addition to passwords, such as cryptographic certificates, smart cards, multi-factor tokens or biometric means, must be used.	Systems Administrator
Password Management systems		
B.	Password management systems must be configured to generate passwords with complexity commensurate with controls.	Systems Administrator

S. No	Description	Responsibility
C.	A password management system must: 1. Enforce the use of individual user IDs and passwords to maintain accountability 2. Enforce a choice of quality passwords based on password policy rules. 3. Force users to change their passwords at the first log-on 4. Enforce periodic password changes. 5. Not display passwords in clear text on the screen when being entered 6. Accounts must be locked out after maximum of three unsuccessful logon attempts. 7. Store password files separately from application system data 8. Store passwords using cryptographic encryption methods. 9. Transmit passwords over a network securely.	Systems Administrator
D.	Password policy: 1. Passwords must be at least eight characters in length. 2. Passwords must be complex, consisting of alphabets, numerals and special characters. 3. Passwords at minimum must be changed every 180 days. Applications and systems must enforce this change. 4. Systems must not accept last five passwords. 5. Passwords must not be shared. Users must be accountable for all actions under their account. 6. Exceptions to the password policy must be subject to approvals from the IT Head, IT Operations Manager and Application Owner after understanding and documenting the risks of not implementing the policy and nature of compensating controls.	Systems Administrator
Use of Privileged Utility Programs		
C.	The use of utility programs that might be capable of overriding system and application controls must be restricted and tightly controlled.	Systems Administrator
D.	The utility programs must be designed such that all execution and access to them is logged by default.	Systems Administrator
Access Controls for Application Source Code		
B.	Access to program source code, designs, specifications, verification plans and validation plans must be	Systems Administrator
C.	Controls and guidelines must then be created to control access to program source libraries in order to reduce the potential for corruption of computer programs.	Systems Administrator
Database Security		
A.	The access to administrative privilege of databases, DBMS utilities must be restricted to authorized personnel only.	Systems Administrator

Access Control- Network and network services

Policy Statement

Access to SmartWorld networks and network services will be restricted by putting in place security controls to limit tampering of critical systems and applications.

Purpose & Objectives

Objective of this policy is to identify security controls to prevent unauthorized access to networks.

S. No	Description	Responsibility
A.	Access to SmartWorld network and network resources must be on need-to-know basis and authorizations must be obtained from appropriate authorities before providing access.	System Administrator / Network Administrator
B.	Connection capability of users must be restricted through access-control lists in firewalls. Additional services more than what is required for the job function must be allowed only after getting approval from appropriate personnel.	System Administrator / Network Administrator
C.	Remote access must be controlled and allowed only after due approval by authorized personnel.	System Administrator / Network Administrator
D.	Access to critical devices like routers and firewalls must be restricted only to authorized personnel.	System Administrator / Network Administrator
E.	Physical and logical access to diagnostic and configuration ports must be controlled.	System Administrator / Network Administrator
F.	Access to third parties must be given after carefully analysing need and after assessing risks involved in providing such access.	IT Team / Networks Team
G.	Periodic review of Firewall audit logs must be done on monthly basis rules must be reviewed on quarterly basis.	IT Team / Networks Team
H.	Incident management process should be followed for any issues observed in firewall logs and rules.	IT Team / Networks Team

Access Control during Emergencies

Policy Statement

Define procedure to follow during emergency situation.

Purpose & Objectives

Objective of this policy is to identify and mandate security controls for access controls mechanisms to be used during emergency situations.

S. No	Description	Responsibility
A.	A formal authorization procedure must be defined for assigning high privileges for "break-glass" administrative accounts and revocation of access privilege after completion of necessary task. Logs and documentation must exist for the same.	IT Operations Manager
B.	Application owners must be notified immediately of all emergency changes and they must conduct a post-facto review of all emergency amendments to their respective production environment.	IT Operations Manager / Department Heads

9. Operation Management

Operation Security

Policy Statement

Effective management of the computing environment would ensure the correct and secure operation of information processing.

Purpose and Objectives

Responsibilities and procedures for the management of the computing environment should be established. This includes development of appropriate operating procedures and incident management procedures.

S. No	Description	Responsibility
Documented Operating Procedures		
A.	Operating procedures must be documented and made available to all users who need them. Procedures must be periodically reviewed, and changes must be authorized by management.	IT Operations Manager

Change Management

Policy Statement

Changes to systems will be only implemented on the basis of formal change requests procedures, which are authorized by the respective Functional head. All changes relating to IT infrastructure and applications are tracked, assessed, classified, approved, implemented and reviewed in a controlled manner to minimize disruption.

Purpose and Objectives

There should be strict control over implementation of changes in order to minimize corruption or malfunctioning of information systems. A formal change request policy should thus be enforced. All changes to systems should be approved and effected on the basis of this formal change request policy.

S. No	Description	Responsibility
Change Management for Information processing systems.		
A.	All change requests raised must be, recorded, classified, prioritized and assessed for risk, impact to business and benefit.	IT Operations Manager
B.	All changes must be tested in accordance to the defined test plan, prior to release. The test plan must also include a roll-back plan.	IT Operations Manager / All employees

S. No	Description	Responsibility
C.	Changes to IT assets (including applications, servers, systems software, and security architecture and network devices) must be performed in a controlled manner. This involves obtaining prior approval, performing impact analysis, testing, and maintaining up-to-date documentation for the entire process. Changes must be tested in a non-production environment before deployment.	IT Team / All employees
D.	Each department must identify and define criteria for emergency changes and define procedures to control the	Functional Head / All employees
E.	The change management process must incorporate validation requirements for regulated systems. In case of changes in application logic & function approval from CRO will also be required.	IT Operations Manager

Capacity Management

Policy Statement

The use of IT resources will be monitored, tuned, and projections made of future capacity requirements to ensure the system performance is not degraded with the increase in demand for the same.

Acceptance criteria for new information systems, upgrades, and new versions shall be established and suitable tests of the system(s) carried out prior to deploying them in the production environment.

Purpose and Objectives

The objective of capacity planning is to enable timely identification of potential performance issues / bottlenecks and address them before it impacts productivity.

S. No	Description	Responsibility
Capacity Management		
A.	Capacity management including analyzing capacity utilization, developing capacity plans and performance measurement are maintained by Cloud Service Provider.	System Administrator

Protection from Malware

Policy Statement

All PCs, Laptops, servers and other information processing equipment of SmartWorld will be adequately protected against malicious software and virus attacks

Purpose and Objectives

Responsibilities and procedures for the management of the computing environment should be established. This includes development of appropriate operating procedures and incident management procedures.

S. No	Description	Responsibility
Controls against malware for Desktops / Laptops and Servers		
A.	Organization must establish and maintain necessary controls on SmartWorld owned Information processing systems to protect against malicious codes.	System Administrator
B.	Controls implemented on the information systems must be capable of addressing the latest vulnerabilities and insecurities that could bring the system down or result in information disclosure or destruction.	System Administrator
C.	All systems within Organization must be configured with the SmartWorld approved Anti-virus software.	System Administrator
D.	Anti-virus products must be configured to update in a timely manner on all systems after the vendor has released a new definition file.	System Administrator
E.	All transferred files must be scanned by SmartWorld approved Anti-virus software prior to execution or use.	System Administrator

Backup and Restoration of Data

Policy Statement

Back-up copies of critical information and software should be taken on a regular basis. Backup and recovery procedures should be documented and tested to ensure that all essential information and software can be recovered in the event of a disaster or failure of media or equipment.

Purpose and Objectives

All critical applications and data stored at SmartWorld location which support critical processes should be backed up regularly in order to ensure that each such application or information can be recovered in the event of failure of a system or loss / corruption of information.

S. No	Description	Responsibility
A.	Identification of Backup requirement All application and operating systems software, data (including databases), application and operating systems configuration information, hardware configuration information (where applicable), software and log files (logs from various systems that need to be backed) essential to the continued operations of SmartWorld must be identified, documented and periodically backed up.	System Administrator
B.	Backup Policy • Backup Frequency: Daily • Incident management process must be followed in case of backup failure. • Backup Retention Period: 9 Years • Retention schedule for backups must take into consideration any specific regulatory/customer specific requirement applicable to Business/ Units.	System Administrator

S. No	Description	Responsibility
C.	Backup Restoration - Information restoration for any IT Asset must be done only after the approval of information owner and IT Operations Manager - Restoration exercise must be done quarterly to check the integrity of backed up data.	Systems Engineers / Executives
D.	Restoration Testing - IT team must document detailed restoration testing processes. - Restoration drills must be carried out in consultation with the information owner. - IT team must ensure that the restored data is deleted after successful completion of restoration testing.	Systems Engineers / Executives
General Clauses		
E.	Business must have a documented backup and recovery procedures for critical information and information systems.	Systems Engineers / Executives
F.	IT department with relevant stakeholders must identify backup and restoration requirements for information within the Unit. The identification process must be in line with business requirements, legal requirements, contractual obligations, regulatory implications, vendor recommendations and other relevant factors.	Systems Engineers / Executives
G.	The backup, mirroring and recovery procedures must be monitored regularly.	Systems Engineers / Executives
H.	Database mirroring mechanisms must be used to mirror critical databases so as to create real time backup of all stored data on a different server (i.e. DR site).	Systems Engineers / Executives

Logging and Monitoring

Policy Statement

Logs need to be maintained and monitored to ensure accountability at all times.

Purpose and Objectives

The objective of this policy is to ensure that all user access to information systems and any critical monitoring events are logged and tracked to ensure accountability.

S. No	Description	Responsibility
Event Logging		
A.	Event logs recording user activities, exceptions, faults and information security events must be produced, retained for a period as defined by business/regulatory requirement and the same must be regularly reviewed.	Systems Administrator
B.	Event logs may contain sensitive data and personally identifiable information. Appropriate privacy protection	Systems Administrator
C.	The company must inform users of monitoring activities and obtain their consent to such activity.	Systems Administrator
Clock Synchronization		

S. No	Description	Responsibility
A.	The clocks of all relevant information processing systems within an organization or security domain must be synchronized to a single reference time source.	Systems Engineers / Executives
B.	A standard reference time for use within the organization must be defined.	Systems Engineers / Executives
Administrator and Operator Logs		
A.	System administrator and system operator activities must be logged, and the logs must be protected and monthly reviewed. SAP administrative SM20 logs will be reviewed on monthly basis.	Systems Engineers / Executives
Protection of Log Information		
A.	Controls must aim to protect against unauthorized changes to log information and operational problems with the logging facility.	System Administrator

Control of Operational Software

Policy Statement

Effective management of the computing environment by setting up controls for software installation will ensure that unnecessary complications are avoided and that SmartWorld systems function smoothly.

Purpose and Objectives

The objective of this policy is to identify controls that must be implemented to manage the installation of software on operational systems.

S. No	Description	Responsibility
Control of Operational Software		
A.	The updating of the operational software, applications and program libraries must only be performed by trained administrators upon appropriate management authorization.	Systems Engineers / Executives
B.	Applications and operating system software must only be implemented after extensive and successful testing.	Systems Engineers / Executives
C.	An audit log must be maintained of all updates to operational program libraries;	Systems Engineers / Executives
D.	Vendor supplied software used in operational systems must be maintained at a level supported by the supplier.	Systems Engineers / Executives
E.	Any decision to upgrade to a new release must take into account the business requirements for the change and the security of the release.	Systems Engineers / Executives
F.	Employees requiring software not published in the standard software list must follow a formal procedure for request of such software from the IT department.(IT Head approval)	Systems Engineers / Executives

10. Technical Vulnerability Management

Policy Statement

Procedures should be defined to identify and remediate technical vulnerabilities on SmartWorld information systems.

Purpose and Objectives

Controls should be in place so as to identify technical vulnerabilities and restrict access to information based on their classification. This is to ensure that the systems are protected from unauthorized access and loss of confidential data.

S. No	Description	Responsibility
A.	SmartWorld must define a formal vulnerability discovery process to identify new vulnerabilities for all SmartWorld IT assets and also put in place a remediation strategy to fix the vulnerabilities within an agreed time frame.	Management
B.	Information about technical vulnerabilities of information systems being used must be obtained in a timely fashion through vulnerability scanning, vendor bulletins and other sources.	IT Operations manager
C.	The organization's exposure to such vulnerabilities must be evaluated and appropriate measures taken to address the associated risk.	IT Operations manager
D.	Penetration tests consisting of both network (including a network layer tests) and application level testing must be performed on an annual basis to identify the possibility of breach of network.	IT Operations manager
E.	All information systems equipped with diagnostic software / penetration testing / vulnerability assessment tools and databases must be secured considering the highly critical data stored on these systems.	IT Operations manager
Threat modeling and source code review		
A.	For SmartWorld sponsored development of critical applications, a threat model must be prepared to assess the risks and corresponding mitigations. A threat model includes a high-level data flow model that illustrates every point in which information moves into or out of the application code or between major parts of the code.	System Administrator
A.	All newly developed and modified applications must undergo at least one source code review exercise after successful user-acceptance testing has been completed.	System Administrator

11. Communications Security

Network Segregation and Security Management

Policy Statement

Create guidelines and procedures to identify network security controls to segregate as well as group systems together with respect to their business function, the sensitivity of the data stored on the systems, and the type of access to be provided to the users of these information services

Purpose and Objectives

Proper network management controls shall be established to protect networks from attacks by hackers from within and outside SmartWorld.

Network Components shall have an appropriate level of security to prevent unauthorized access to SmartWorld network. These components will be placed in physically secure locations and access should be restricted to authorized personnel only.

Firewalls shall be used to protect information systems providing access to sensitive or confidential information or hosting critical applications.

Remote access to SmartWorld business information will be based on an appropriate level of identification and authentication and suitable access control mechanisms.

S. No	Description	Responsibility
Controls for Network and Network services		
A.	All network and network services in SmartWorld must be identified and documented.	IT Operations Manager
B.	System default settings will be reviewed prior to installation to determine potential security holes. Settings that could potentially compromise security must be changed prior to the system being placed in the network.	Network Administrator
C.	Networks must be logically or physically divided based on the criticality of the information stored in the networks. If the network is logically separated, appropriate perimeter security devices must be put in place. If the network is physically separated, controls must be in place to protect physical access to the network points at all ends.	Network Administrator
D.	Routing controls must be implemented for networks to ensure that computer connections and information flows do not breach the access control requirements of the business applications.	Network Administrator
Internet Service Management		
E.	All Internet activity must pass through SmartWorld Firewall and the Proxy gateway server to the Internet so that access controls and related security mechanisms can be applied.	Network Administrator
Wireless Networks		
F.	All wireless access points must be approved and centrally managed by the IT Team. The addition of new wireless access points within SmartWorld premises must be approved by the designated authorized personnel, who will perform the risk analysis before introducing new wireless access points.	Network Engineer
G.	Highest possible authentication mechanism and encryption standard must be used for providing access through wireless communications.	Network Engineer
H.	All access points must be physically secured and configured in such a way that the coverage is within SmartWorld office or premises.	Network Engineer
I.	Use of the wireless network is subject to the same guidelines as SmartWorld Acceptable usage policy.	Network Engineer
J.	Periodic wireless network vulnerability analysis must be conducted to identify rogue access points and devices connected to the network.	Network Engineer
Network Security Management		

S. No		Responsibility
K.	All network equipment's and communication lines must be identified, documented and updated regularly.	Network Engineer
L.	Network diagrams at all levels (WAN & LAN segments) must be maintained and updated regularly.	Network Engineer
M.	Minimum Baseline Security Standards (MBSS) must be developed and maintained and all network equipment's must be configured as per MBSS.	Network Engineer
N.	All Connection between SmartWorld's network and any third-party network must be established only after appropriate approval from authorized personnel.	Network Engineer
Network Assessment		
O.	Network vulnerability assessments must be performed on an ongoing basis by competent personnel. The risks identified must be documented in the assessment report.	Network Administrator
P.	Assessment reports must be used to create corrective/improvement plans and the same must be tracked to closure.	Network Engineer
Q.	Third party independent network assessment must be performed annually in order to provide assurance to the management, customers and stakeholders.	Network Engineer

Patch Management

Objective

The objective of this policy is to identify security controls related to patch management of software and firmware of computer technology infrastructure within SmartWorld.

This policy covers all servers, workstations, network devices, operating systems (OS), applications, and other information assets for which vendors provide system patches or security updates

S. No	Description	Responsibility
A.	Security patches, software patches that improve functionality, consolidated set of patches (e.g. Windows service packs), and other software updates must be installed for all infrastructure components such as servers, network devices and applications.	System Administrator
B.	All systems must be patched within an acceptable window of time, after patch release announcement from the vendor.	System Administrator
C.	Testing must be undertaken for product upgrades, patches and fixes prior to acceptance and release of the upgrade process into a production environment.	System Administrator
D.	Automated tools will scan for available patches and patch levels, which will be reviewed as specified in the Patch Application Guidelines.	System Administrator
E.	Manual scans and reviews will be conducted on systems for which automated tools are not available.	System Administrator
F.	An informal risk assessment will be performed within 2 business days of the receipt of notification of patches. If	System Administrator

S. No	Descriptio	Responsibility
	a determination regarding the applicability of the patch or mitigating controls cannot be made at that time a formal risk assessment will begin.	
G.	Vendor-supplied patch documentation will be reviewed in order to assure compatibility with all system components prior to being applied.	System Administrator
H.	Patches will be successfully tested on non-production systems installed with majority of applications/services prior to being loaded in production system.	System Administrator
I.	Successful backups of mission-critical systems will be verified prior to installation of patches and a mechanism for reverting to the patch levels in effect prior to patching	System Administrator
J.	Patches will be applied during an authorized maintenance window in cases where the patch application will cause a service interruption for mission-	System Administrator
K.	Patches will be prioritized and applied in accordance with	System Administrator
L.	Logs will be maintained for all system categories (servers, secure desktops, switches, etc.) indicating which devices have been patched. System logs help record the status of systems and provide continuity among administrators. The log may be in paper or electronic form. Information to be recorded will include but is not limited to date of action, administrator's name, patches and patch numbers that were installed, problems encountered,	System Administrator
M.	In the event that a system must be, reloaded, all relevant data on the current OS and patch level will be recorded. The system should be brought back to the patch levels in	System Administrator
N.	In the event that a patch will not be applied due to incompatibility or risk assumption, precautions to mitigate the risk of exploitation to the College	System Administrator
O.	Automated tools will scan for available patches and patch levels, which will be reviewed as specified in the Patch	System Administrator

12. Suppliers and Partners

Agreements and SLA Monitoring

Policy Statement

This policy applies to the maintaining or processing of production and information systems that cannot be done internally, applications development, consulting, outsourcing of functional areas, and other information services.

Objectives

Outsourcing arrangements should address the risks, security controls and procedures for information systems, networks and / or IS environments. This should be explicitly specified on the contract, which would refer to all the necessary security conditions and service levels to ensure compliance with SmartWorld security policies and standards.

The SLA should provide both SmartWorld and the service provider the necessary checks-and-balances for a mutually satisfying and rewarding partnership. This policy section lays down some broad service level agreement guidelines for SmartWorld.

S. No	Description	Responsibility
A.	SmartWorld must ensure that all services provided by third party organizations (outsourced party or contractors or vendors) are clearly identified and the relationship with the outsourced party is managed through clearly identified point of contacts in SmartWorld and the outsourced party.	Functional Heads, IT Team
B.	A formal contract must be entered between SmartWorld and all third parties providing service to SmartWorld or using SmartWorld's information systems. The services to be provided by the outsourced party must be covered by a Service Level Agreement ('SLA') that takes into consideration expected levels of service, security, monitoring, contingency and other stipulations as appropriate.	Functional Heads, IT Team
C.	Contracts/Agreements must include information security requirements to ensure compliance to SmartWorld's security policies and procedures.	Functional Heads, IT Team
D.	SmartWorld must assess and identify potential risks to SmartWorld's information security as a result of outsourcing information or data processing functions or services to third party organization.	Functional Heads, IT Team
E.	Periodic reviews of the supplier's services must be conducted against the suppliers SLA's to ensure that business needs and contractual obligations are being met.	Functional Heads, IT Team
F.	Non-Disclosure/ Confidentiality agreements to protect SmartWorld's information asset (Prior to providing the access of data)	Functional Heads, IT Team
G.	Changes to the provision of services by suppliers, including maintaining and improving existing information security policies, procedures and controls, must be managed, taking account of the criticality of business information, systems and processes involved and re-assessment of risks.	Functional Heads, IT Team

13. Business Continuity Management

Policy Statement

SmartWorld should identify security controls for business continuity of SmartWorld in the event of a disaster. This policy establishes the basic principles and framework necessary to ensure emergency response, resumption, and permanent recovery of SmartWorld's business operations during and after a business interruption due to either man-made or natural disasters.

Purpose and Objectives

Continuity plans should be developed for all critical infrastructure, processes and information supporting SmartWorld information processing systems. This continuity plan would assist in preventing disruption of and/or facilitate recovery of critical processes operated by SmartWorld.

S. No	Description	Responsibility
A.	All businesses within SmartWorld must develop a managed process for business continuity throughout the organization that addresses the information security requirements as well.	Head - IT
B.	A comprehensive Business Continuity Plan (BCP) must be developed and implemented in order to maintain or restore business operations in the required time scales following interruption to, or failure of, critical business processes. The BCP must include effective Disaster Recovery procedures for quickly recovering from an emergency with minimum impact to the company's operations.	Head - IT
C.	All changes to business continuity plan(s) must be documented, reviewed and approved by management.	Management
D.	The business continuity plans must be maintained, updated and tested to identify incorrect assumptions, oversights, or changes in equipment or personnel. Annual BCP readiness testing should be done.	IT Operations Manager

Redundancy

Policy Statement

SmartWorld should define protocols for critical SmartWorld systems that are required to be highly available. This policy establishes the basic principles and framework necessary to ensure that alternative process will be available on standby mode during and after a business interruption due to either man-made or natural disasters.

Purpose and Objectives

The objective of this policy is to achieve high-availability and reliability for all critical systems and infrastructure components by providing the process alternative to a failing condition.

S. No	Description	Responsibility
A.	Critical information processing systems must be identified and deployed with redundancies that are sufficient to meet availability requirements.	System Administrator

14. Incident Management

Policy Statement

This policy applies to ensure Information Security Incidents shall be reported promptly and responded to in a quick, effective and orderly manner in order to reduce the

negative effect of incidents, to repair damage and to inform policy and mitigate future risks

Purpose and Objectives

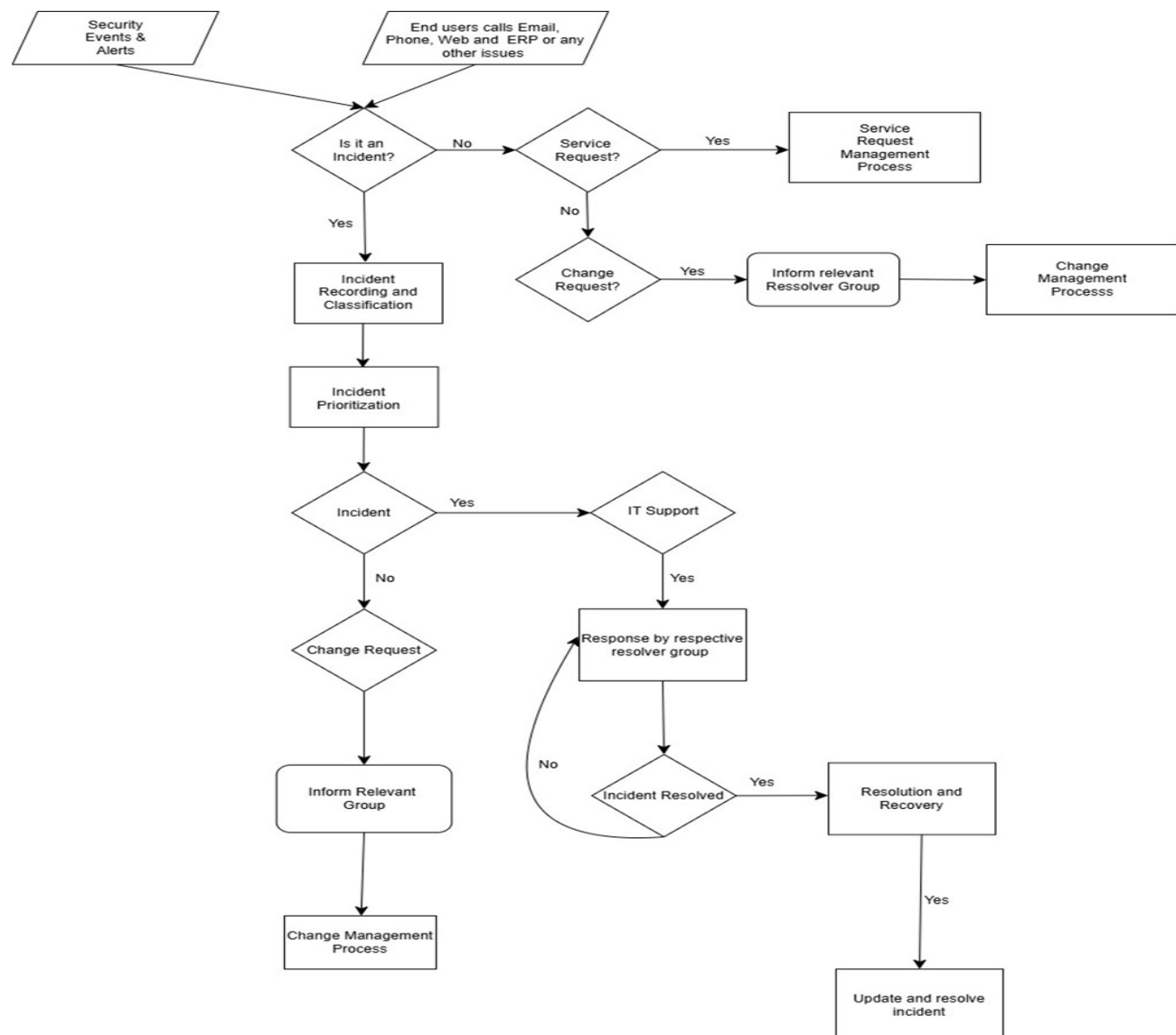
The purpose of this policy is to ensure a consistent and effective approach to the management of Information Security Incidents, including communication on security events and weaknesses. It enables the efficient and effective management of Information Security Incidents by providing a definition of an Information Security Incident and establishing a structure for the reporting and management of such incidents.

S. No	Description	Responsibility
Responsibilities and procedures		
A.	Information security related events and incidents may cause disruption to operations. Responsibilities shall be established for a quick, effective and orderly response for all reported information security events and incidents and Management responsibilities shall be defined.	IT Operations Manager
B.	The main objectives of the Information Security Incident Management Procedure shall be agreed with the Management and personnel responsible for handling information security events and incidents shall understand Organization's priorities of handling the observed or reported situation. References from previously reported security incidents shall be taken to effectively handle current security incidents to reduce time and efforts.	Management
Reporting information security events and weaknesses		
C.	Information Security Events and Incidents include impacts to information and information processing facilities like hardware failure, software corruption, technical control failure, unauthorized physical access, natural disasters affecting assets like cyclone, flood etc. All employees, sub-contractors and partners shall report observed or suspected information security events/incidents that might be, or could lead to, unauthorized access, loss or inaccuracy of Organization's sensitive information thereby resulting in the breach of information security	IT team, All Employees

Priority Table

Priority	Response Time	Resolution Time	RCA to be submitted	RCA submission time (Post Incident Resolution)
P1	15 Mins	2 Hrs.	Yes	Within 24 Hours
P2	30 Mins	8 Hrs.	Yes	Within a Week
P3	60 Mins	12 Hrs.	No	Not Applicable
P4	120 Mins	24 Hrs.	No	Not Applicable

Incident Management Workflow



Incident Response Plan.

S. No	Description	Responsibility
Plan and Prepare		
A.	Create an action item checklist for incident response.	IT Operations Manager
B.	Include plans for development, team creation and training, and establish supporting technologies	IT Operations Manager
C.	Conduct periodic review and test the plan. Regularly conduct regularly meetings and trainings.	IT Team
Identification		
D.	Detect and identify an incident	IT Team
E.	Categorize (critical, high, medium, low) and classify incident (level 1 to level 6) and decide on immediate containment measures according to the category of the incident.	IT Team
F.	Establish incident response team, perform a detailed assessment and formulate specific plan of action	Head – IT, IT Operations Manager
G.	Confirm roles and responsibilities, and establish reporting lines and frequency	IT Operations Manager
Containment		

S. No	Description	Responsibility
H.	Determine the necessary steps to contain the damage or risk posed by the incident	IT Operations Manager
I.	Document the containment plan and, perform tests on the specified plan.	IT Operations Manager
J.	Deploy the containment plan and monitor for effectiveness or adverse impacts	IT Operations Manager
Investigation		
K.	Identify sources of potential evidence and preserve or collect them	IT Operations Manager
L.	Process and analyse evidence and determine the root cause of the incident	IT Operations Manager
M.	Report and undertake follow-on activities to support regulatory responses	IT Operations Manager
Remediation		
N.	Develop and implement a plan to perform root cause analysis of the incident	IT Operations Manager
O.	Document the plans and controls and, if possible, test technical mitigation methods	IT Operations Manager
P.	Deploy eradication controls and rebuild affected asset	IT Operations Manager
Q.	Monitor for re-occurrence and adverse impacts	IT Operations Manager
Lessons Learned		
R.	Finalize the incident response documentation and conduct lessons learned meetings	IT Operations Manager
S.	Provide feedback to team members and update plan with improvements	IT Operations Manager
T.	Make long-term security improvements to reduce the impact of similar future incidents	IT Operations Manager
SLA Violation		
U.	In case of SLA Violation, calls should be escalated to IT Operation Manager and HOD-IT. SLA violation email on daily basis.	IT Helpdesk

Appendix 1: Risk Impact Matrix

Type of Impact	Organizational and operational scope	Reputational Impact on stakeholders (customers / employees)	Legal / Compliance / Environmental Impact	Financial Impact	Examples
Critical	Enterprise wide – Inability to continue business operations globally	Permanent loss of stakeholder confidence resulting in legal action, interruption in enterprise operations globally, and /or defection to competition	Global restriction on conducting business in certain product lines	a. Barred from doing business in global locations b. Compensation, fines or expense > 1 Million USD	a. Site/System unavailability due to natural calamity like fire, earthquake etc. b. Unauthorized disclosure of Confidential and/or Restricted information

Type of Impact	Organizational and operational scope	Reputational Impact on stakeholders (customers / employees)	Legal / Compliance / Environmental Impact	Financial Impact	Examples
High	Significant Impact - Ongoing interruptions within 2 or more Departments	Sustained loss in 2 or more Departments	Significant fines or limitations on conducting business in certain product lines	a. Sanctions imposed by regulatory bodies in a specific country b. Compensation, fines or expenses > 100,000 USD	a. Theft or loss of information asset storing Confidential/Restricted information b. Virus or malware spread and service degradation c. Site power outage, partial disruption of operations d. Non-compliance with Information Security Policy or Procedures
Medium	Moderate Impact – 1 Department impacted	Limited to minor loss / short term impact to the stakeholder's group (employees)	Limited actions against company with limited effects on operations	a. Compensation, fines or expenses < 100,000 USD	a. Attempts (either failed or successful) to gain unauthorised access to a system or information
Low	Minimal Impact	Minimal Impact	Minimal Impact	a. Expenses < 50,000	a. Receiving and forwarding chain letters including scam warnings and other emails which encourage the recipients to forward to others

ANNEXURE 1

Application	Backup retention	IT Remarks
SAP	9 Years	
Salesforce	9 Years	Last backup copy will be available
4 QT	9 Years	
Tally	9 Years	
ITS	9 Years	
DMS	9 Years	
Camera's backup	30 days	
Email	Till Active in system plus buffer	
Novade	Till DLP after project completion	Estimated minimum period 9 years
Visilean	Till DLP after project completion	Estimated minimum period 9 years
Gemba applications	9 Years	
Fileserver /One drive	9 Years	
Reloy	9 Years	